

absence of the DPO”;

“the email address XX does not correspond to a certified email (PEC) but is a shared address with the two members of the DPO Office, as provided for by the Guidelines of the Garante for electronic mail and the internet of March 1, 2007, in order to monitor the mail directed to the Data Protection Officer, even in the absence of the DPO”;

3. Conclusions.

In light of the above, it is necessary to assess whether the processing of personal data related to the vaccination status of the employees was carried out in compliance with the applicable regulations, particularly with regard to the principles of necessity and proportionality, as well as the rights of the data subjects involved.

4. Decision.

The Garante for the Protection of Personal Data, having considered the documentation submitted and the observations made, decides as follows:

a) to acknowledge the complaint filed by Ms. XX regarding the communication of vaccination status to unauthorized parties;

b) to order the Hospital Company to ensure that any future communications regarding personal data, particularly sensitive data such as vaccination status, are conducted in compliance with the principles set forth in the GDPR and the national legislation on data protection;

c) to remind the Hospital Company of the importance of ensuring that access to personal data is limited to authorized personnel only, and that appropriate measures are taken to protect the confidentiality and integrity of such data.

This decision shall be communicated to the parties involved and published in accordance with the provisions of the applicable regulations.

Rome, January 30, 2025

The President

Prof. Pasquale Stanzione

temporary absence of the same, and it is the contact data indicated in the company information”;

“on that occasion, the attendance/absence situation of the two employees was transmitted to the email address of the Data Protection Officer’s Office precisely to avoid the risk, using the named company email box, of sending the information to the employee with the same name as the D.P.O., as it was not evident at that moment to the sender whether to use the address “XX or instead “XX, nor was it easy to verify with the directly interested party, given the time of sending the email (around 19:30). The time of sending was determined by the need to ensure that the coordinator of the two resources was aware of their situation, in order to comply with the regulatory requirements, particularly regarding the verification of the prohibition of access, the following day, to the workplace by the suspended employees”;

“the two employees who have access to this mailbox were authorized to know the communications related to the disengagement of service activities; however, regarding the information contained in the email in question, it does not seem that their accidental reading revealed mutually unknown situations, given the context outlined above. It should also be added that the probability that the colleague of Ms. XX could view the email was quite low because, being suspended from service, he had no duties to consult the company mail”.

With a note dated XX (prot. n. XX), the Office, based on the elements acquired, the checks carried out, and the facts emerged following the investigative activity, notified the Hospital Company, pursuant to art. 166, paragraph 5, of the Code, of the initiation of the procedure for the adoption of the measures referred to in art. 58, paragraph 2, of the Regulation, for having communicated personal data relating to the vaccination status of workers in the absence of an appropriate legal basis, in violation of articles 5, 6, and 9 of the Regulation, as well as 2-ter and 2-sexies of the Code.

With the same note, the aforementioned holder was invited to submit written defenses or documents to

the Guarantor or to request to be heard by the Authority (art. 166, paragraphs 6 and 7, of the Code, as well as art. 18, paragraph 1, of law November 24, 1981, n. 689).

With a note dated XX (prot. n. XX), the Hospital Company, which did not request to be heard, submitted a defensive memorandum, stating, in particular, that:

“this concerns an alleged violation of personal data occurring within the framework of the control and verification of the vaccination obligation as provided for by D.L. November 26, 2021, n. 172, which assigned to the Employer the procedure for verifying compliance with the vaccination obligation by workers”;

“in the undersigned Company, this procedure has been regulated by a regulation, approved by resolution n. XX of XX, which assigned to the Personnel Office all administrative duties for managing the related practices”;

“the event is attributable to the sending of an email on XX directed to provide the DPO, to whom it was addressed, with the necessary information for organizational purposes regarding the established absence from service of the two resources assigned to the office”;

“the content [of the email] is extremely concise and does not provide any indication regarding the type of vaccination of the employee, nor the reason for the suspension of the other colleague, nor is there any specific reference to COVID”;

“the text of the email does not contain any other particular personal data relating to the interested parties. This is a unique and isolated event that involved only the two subjects pertaining to the alias in addition to the DPO himself. The duration of the alleged violation can be said to be contained, in fact, it is an incident of instantaneous formation that did not persist over time. Regarding the severity of the same, no harmful events are known concerning the interested parties attributable to the communication of the data in question”;

“as for the subjective element that determined the conduct in question, it is believed, following the investigation carried out, that the alleged violation is the result of an absolutely accidental and involuntary behavior, attributable to a mere error of the sender who, not having reached the Data Protection Officer by phone, provided the necessary communication to the email address: dpo@cittadellasalute.to.it, believing in good faith that there were no other authorized users to access the email”;

“to avoid undue dissemination of data, by resolution n. XX of XX [...] the AOU Città della Salute e della Scienza di Torino, implementing what is provided by D.L. n. 127, defined the company procedural lines applicable to art. 1 of D.L. n. 127/2021 regarding the obligations of the employer and with subsequent resolution n. XX of XX [...] it was, among other things, assigned to the Personnel Office the execution of all administrative duties for managing the related practices”;

“the life cycle of the processing, as can be inferred from the aforementioned procedures, has been defined in such a way as to minimize the risk of undue dissemination/communication of information and also provides for the use of a dedicated email address: applicazonedl44@cittadellasalute.to.it which can only be accessed by authorized personnel belonging to the Office that manages the related obligations”;

“subsequent to the event that occurred, the undersigned Company approved and published on the company Intranet the form for the request for new but also within the organization itself.

3.2.1 The communication of personal data regarding the vaccination status of employees must be limited to those who have a legitimate need to know such information for the performance of their duties. The employer must ensure that access to sensitive data is restricted and that appropriate safeguards are in place to protect the confidentiality of such information.

3.2.2 In this specific case, the sharing of vaccination status between the RPD and the employees involved raises concerns about compliance with data protection principles. The employer must demonstrate that the communication of this information was necessary for the management of the workplace and that it adhered to the principles of necessity and proportionality.

3.3. Conclusion.

Based on the findings of the investigation, it is concluded that while the processing of personal data related to vaccination status may be lawful under certain conditions, the manner in which this data was communicated in the present case did not fully comply with the requirements set forth by data protection legislation. The employer must take immediate steps to rectify this situation and ensure that all future communications regarding sensitive personal data are conducted in accordance with legal obligations and best practices in data protection.

4. Recommendations.

4.1 The employer should implement stricter controls and protocols for the handling of sensitive personal data, particularly regarding vaccination status, to prevent unauthorized access and disclosure.

4.2 Training should be provided to all employees involved in data processing activities to ensure they understand their responsibilities under data protection laws and the importance of safeguarding personal information.

4.3 Regular audits should be conducted to assess compliance with data protection regulations and to identify areas for improvement in data handling practices.

5. Final Remarks.

The protection of personal data is a fundamental right that must be respected and upheld by all organizations. It is essential for the employer to foster a culture of compliance and accountability in relation to data protection to maintain the trust of employees and to avoid potential legal repercussions.

****Translation:****

but also within work contexts involving unauthorized subjects (see points 2, 4, 5.1, and 5.3 of the "Guidelines on the processing of personal data of workers for the management of the employment relationship in the public sector," dated June 14, 2007, published in G.U. July 13, 2007, no. 161, and on www.garanteprivacy.it, web doc no. 1417809).

In this regard, according to the consolidated orientation of the Garante (see, already provisions of October 18, 2012, no. 296, web doc no. 2174351 and no. 297, web doc no. 2174582, as well as provision of May 8, 2013, no. 232, web doc no. 2501216, provision of October 3, 2013, no. 431, web doc 2747867, and provision of July 31, 2014, no. 392, web doc no. 3399423), recently confirmed in numerous provisions on individual cases, personal data of employees processed for the purposes of managing the employment relationship cannot, as a rule, be disclosed to subjects other than those who are part of the specific employment relationship (see definitions of "personal data" and "data subject," contained in Article 4, paragraph 1, no. 1, of the Regulation), or to those who - also taking into account the definition of "third party," contained in Article 4, paragraph 1, no. 10, of the Regulation - are not authorized to process them due to the assigned duties and the organizational choices of the data controller; this also with reference to the correct management of communications between offices and personnel in the emergency context (see, among many, most recently, provision no. 606 of September 26, 2024, web doc 10068155; but see also provision no. 223 of June 1, 2023, web doc 9916798, provision no. 322 of September 16, 2021, web doc no. 9711517, and provisions cited therein).

This is because, as confirmed by the Garante, even the provision of data to subjects who, although part of the data controller's organization, due to the role performed and the functions exercised, cannot be considered "authorized" to process (see Articles 4, no. 10, 28, paragraph 3, letter b), 29, and 32, paragraph 4, of the Regulation, as well as Article 2-quaterdecies of the Code), may lead to a communication of personal data in the absence of a legal basis.

It is necessary to take into account, in general, the particular context that frames the facts in question following the provision of anti-Sars-cov-2 vaccination as an "essential requirement for the exercise of the profession and for the performance of work activities," which was initially provided for healthcare professionals and operators of healthcare interest by virtue of Article 4 of Decree-Law April 1, 2021, no. 44 (converted into law no. 76 of May 28, 2021 - Urgent measures for the containment of the

COVID-19 epidemic, regarding anti-Sars-cov-2 vaccinations, justice, and public competitions) in order to protect public health and maintain adequate working safety conditions and in the provision of care and assistance services.

As is known and as also recalled by the hospital company, this provision was followed by the applicable sector regulations in the specific case (Decree-Law November 26, 2021, no. 172, "Urgent measures for the containment of the COVID-19 epidemic and for the safe conduct of economic and social activities") which introduced Article 4-ter in Decree-Law no. 44 of 2021, providing, also for administrative personnel of healthcare facilities (who, in any capacity, carried out their work activity "in the structures referred to in Article 8-ter of Legislative Decree no. 502/1992"), as already established for medical personnel, that anti-Sars-cov-2 vaccination, starting from XX, constituted an "essential requirement for the performance of work activities." The aforementioned decree-law also provided that the checks regarding compliance with the vaccination obligation were entrusted, respectively, to employers or to the heads of the institutions where such categories of data subjects were providing service.

The above-mentioned regulations - currently no longer in force due to subsequent legislative interventions (see most recently, Decree-Law October 31, 2022, no. 162) - constituted, from the perspective of data protection, the scope of processing permitted, respectively, to employers and other institutional subjects involved, as well as the legal basis in accordance with the Regulation, establishing, in particular, that the communication of the suspension from service of the worker, in case of failure to undergo vaccination, was to be made exclusively to the interested party (see Article 4-ter, paragraph 3, of Decree-Law no. 44 of 2021: "In case of failure to present the documentation referred to in the second and third periods, the subjects referred to in paragraph 2 ascertain the non-compliance with the vaccination obligation and immediately notify the interested party in writing").

The legislator had, therefore, introduced a complex verification system of the professional requirement for such categories of workers, which involved various institutional subjects, and provided for data flows between them, as well as the consequences, including in terms of suspension from the exercise of the profession and from the possible employment relationship, for the worker lacking the aforementioned requirement.

The processing of personal data necessary for the verification of the aforementioned professional requirement, therefore, had to be carried out in strict compliance with the limits and conditions provided by this legislative framework of reference which constituted its legal basis and uniformly delineated at the national level the scope of processing permitted to each of the aforementioned subjects (Articles 5 and 6, paragraph 2, letters b) and g), of the Regulation and Article 2-sexies of the Code; as highlighted in numerous provisions of the Garante during the emergency period and, in particular, in the opinions.

****Resolution on the Subsequent Implementation Provisions of the Above-Mentioned Framework****
(see, among others, provision of December 13, 2021, no. 430, web document no. 9727220).

Having stated the above, with regard to the specific case, it appears that - although the communication in question was made solely to avoid a potential sending error "to the namesake employee of the D.P.O." in the urgency of making such communication during the pre-holiday period - the solution actually adopted, using the shared email box dpo@cittadellasalute.to.it to provide the head of the Office with the necessary information regarding the organizational plan and the presence of staff during the Christmas period, nonetheless resulted in an unlawful communication of personal data, making both the complainant and the other colleague aware of each other's vaccination status. Therefore, without prejudice to the necessity for the head of the organizational unit to know the aforementioned information concerning their collaborators, namely the complainant and the other interested employee (see ex art. 4 ter, paragraph 2, decree law 44 of 2021), it must be considered that, since both interested parties had access to the same shared email account (dpo@cittadellasalute.to.it), each of them, as a result of the aforementioned sending, was made aware of the other's vaccination status as well as other personal information related to the specific employment relationship with the Hospital Company, in particular, the complainant's vaccination and

the other colleague's lack of vaccination and the consequent suspension from service.

In light of the above considerations, such behavior, although isolated and occurring in the immediate vicinity of the Christmas holidays, resulted in a communication of data, including health-related data, of the complainant, particularly concerning the communication of the date on which they underwent vaccination against Sars-cov-2 (given the definition in art. 4, paragraph 1, no. 15 of the Regulation); this communication also concerned personal data related to the lack of vaccination, resulting in the suspension from service of the other employee.

In light of the above considerations, the Hospital Company, which processed personal data solely through authorized personnel within the framework of the aforementioned sector regulations in force at the time, has, however, mistakenly believed it was adopting the preferable solution in the context of reference, proceeded with an unjustified communication of personal data, including health-related data, in favor of subjects who were not mutually authorized to process them, in the absence of an adequate legal basis, in violation of articles 5, 6, and 9 of the Regulation, as well as 2-ter and 2-sexies of the Code.

****4. Conclusions.****

In light of the evaluations mentioned above, it is noted that the statements made by the data controller during the investigation - the truthfulness of which may be subject to accountability under art. 168 of the Code - although worthy of consideration, do not allow for overcoming the objections notified by the Office with the initiation of the procedure and are insufficient to permit the archiving of the present procedure, as none of the cases provided for by art. 11 of the Garante Regulation no. 1/2019 apply.

Therefore, the preliminary evaluations of the Office are confirmed, and the unlawfulness of the processing of personal data carried out by the Hospital Company is noted for having communicated information also related to the health of the complainant, particularly concerning the communication of the date on which they underwent vaccination against Sars-cov-2 (given the definition in art. 4, paragraph 1, no. 15 of the Regulation), as well as personal data related to the lack of vaccination, resulting in the suspension from service of the other employee, in violation of articles 5, 6, and 9 of the Regulation, as well as 2-ter and 2-sexies of the Code.

Considering that the violation of the aforementioned provisions occurred as a result of a single conduct (same processing or interconnected treatments), art. 83, paragraph 3, of the Regulation applies, according to which the total amount of the administrative pecuniary sanction does not exceed the amount specified for the most serious violation. Given that, in this case, the most serious violations, related to articles 5, 6, and 9 of the Regulation, as well as 2-ter and 2-sexies of the Code, are subject to the sanction provided for by art. 83, paragraph 5, of the Regulation, as also referenced by art. 166, paragraph 2, of the Code, the total amount of the sanction is to be quantified up to €20,000,000.

In this context, considering, in any case, that the conduct has exhausted its effects, taking into account the assurances provided by the Hospital Company regarding the organizational measures subsequently adopted, aimed at preventing similar situations from occurring in the future, the prerequisites for the adoption of further corrective measures under art. 58, paragraph 2, of the Regulation do not exist.

****5. Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (articles 58, paragraph 2, letter i and 83 of the Regulation; art. 166, paragraph 7, of the Code).****

The Garante, pursuant to articles 58, paragraph 2, letter i) and 83 of the Regulation as well as art. 166 of the Code, has the power to "impose an administrative pecuniary sanction pursuant to article 83, in addition to the [other] corrective measures [referred to in this paragraph, or in lieu of such measures, depending on the circumstances of each individual case]" and, in this context, "the College [of the Authority] adopts the injunction order, which also provides for the application of the accessory administrative sanction of its publication, in whole or in part, on the Authority's website pursuant to Article 166, paragraph 7, of the Code" (Article 16, paragraph 1, of the Authority's Regulation No. 1/2019).

In this regard, considering Article 83, paragraph 3, of the Regulation, in this specific case, the violation of the aforementioned provisions is subject to the application of the administrative pecuniary sanction provided for by Article 83, paragraph 5, of the Regulation.

The aforementioned administrative pecuniary sanction imposed, depending on the circumstances of each individual case, must be determined in amount taking into due account the elements provided for by Article 83, paragraph 2, of the Regulation.

Considering that:

- with specific regard to the nature, severity, and duration of the violation, it should be noted that the communication occurred in reference to the data of only two data subjects and, although due to human error, the communication resulted in mutual knowledge of the vaccination status (Article 83, paragraph 2, letter a), of the Regulation);
- with specific regard to the subjective profile, the violation was committed, due to a misjudgment, solely to avoid the risk of sending "to the namesake employee of the D.P.O." in the urgency of making such communication during the holiday period and to provide the office manager with the necessary information (Article 83, paragraph 2, letter b), of the Regulation);
- the processing also involved data belonging to special categories as referred to in Article 9 of the Regulation, in particular, with reference to the vaccination that occurred as a health service (cf. Article 83, paragraph 2, letter g), of the Regulation),

it is believed that, in this case, the level of severity of the violation committed by the data controller is medium (cf. European Data Protection Board, "Guidelines 4/2022 on the calculation of administrative pecuniary sanctions pursuant to the GDPR" of May 24, 2023, point 60).

That said, it is considered that, for the purposes of quantifying the sanction, the following circumstances should be taken into account:

- the Hospital Company has offered good cooperation with the Authority during the investigation (Article 83, paragraph 2, letter f), of the Regulation);
- there are some previous violations of certain provisions of the Regulation and the Code, although in a different data processing context (cf. Article 83, paragraph 2, letter e), of the Regulation);
- the violation, which nonetheless represented an isolated case, occurred during a period characterized by numerous difficulties for hospital companies on an organizational level, related to the issues of the emergency period characterized by the spread of the Sars-cov 2 virus (Article 83, paragraph 2, letter k), of the Regulation).

In light of the aforementioned elements, assessed as a whole, it is deemed appropriate to determine the amount of the pecuniary sanction at the sum of €6,000 (six thousand) for the violation of Articles 5, 6, and 9 of the Regulation, as well as Articles 2-ter and 2-sexies of the Code, as an administrative pecuniary sanction deemed, pursuant to Article 83, paragraph 1, of the Regulation, effective, proportionate, and dissuasive.

It is also considered that, pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Authority's Regulation No. 1/2019, the publication of this section containing the injunction order on the Authority's website should proceed. This is in consideration of the fact that sensitive information regarding the vaccination status of two workers has been communicated, which has led to the circulation, in the workplace, of personal data relating to special categories.

Finally, it is noted that the conditions referred to in Article 17 of Regulation No. 1/2019 are met.

ALL OF THE ABOVE CONSIDERED, THE AUTHORITY declares, pursuant to Article 57, paragraph 1, letter f), of the Regulation, the illegality of the processing carried out by the Hospital Company for violation of Articles 5, 6, and 9 of the Regulation, as well as Articles 2-ter and 2-sexies of the Code, in the terms indicated in the reasoning;

ORDERS

the Hospital-University Company Città della Salute e della Scienza di Torino, represented by the legal

representative pro tempore, with registered office at C.so Bramante 88 - 10126 Torino (TO), Tax Code 10771180014, to pay the sum of €6,000 (six thousand) as an administrative pecuniary sanction for the violations indicated in the reasoning.

It is stated that the offender, pursuant to Article 166, paragraph 8, of the Code, has the option to settle the dispute by payment, within 30 days, of an amount equal to half of the imposed sanction;

ORDERS

the aforementioned Hospital Company, in case of failure to settle the dispute pursuant to Article 166, paragraph 8, of the Code, to pay the sum of €6,000 (six thousand) according to the methods indicated in the attachment, within 30 days from the notification of this provision, under penalty of the adoption of subsequent enforcement actions pursuant to Article 27 of Law No. 689/1981;

DISPOSES

- pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Authority's Regulation No. 1/2019, the publication of the injunction order on the Authority's website;
 - pursuant to Article 154-bis, paragraph 3 of the Code and pursuant to Article 37 of the Regulation of the Authority No. 1/2019, the publication of this provision on the website of the Authority;
 - pursuant to Article 17 of the Regulation of the Authority No. 1/2019, the annotation of violations and the measures adopted in accordance with Article 58, paragraph 2 of the Regulation, in the internal register of the Authority provided for by Article 57, paragraph 1, letter u) of the Regulation.
- Pursuant to Articles 78 of the Regulation, 152 of the Code, and 10 of Legislative Decree No. 150/2011, an appeal against this provision may be filed before the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, January 30, 2025

THE PRESIDENT

Stanzione

THE REPORTER

Stanzione

THE SECRETARY GENERAL

Mattei